unidees

TLP:CLEAR

CSIRT · AVIS DE VULNÉRABILITÉ · UNIDEES-CSIRT-221026-001

⚠ ALERTE CRITIQUE

PHP : deux failles critiques permettent de prendre le contrôle d'un serveur web

CVE-2026-109618 · CVE-2026-109619

9,8 SCORE CVSS 3.1 LE PLUS ÉLEVÉ (NVD) SUR 10

RÉFÉRENCE	VERSION	CLASSIFICATION
UNIDEES-CSIRT-221026-001	v1.1	Public
PUBLICATION	**IDENTIFICATION**	**SOURCES**
22/10/2026	21/10/2026	Projet PHP (php.net), CERT-FR, NVD

RÉSUMÉ

Le 21 octobre 2026, le projet PHP a publié des correctifs pour deux vulnérabilités qui permettent **d'exécuter du code à distance, sans authentification**, sur un serveur qui fait tourner PHP. Le CERT-FR indique avoir connaissance de preuves de concept pour des déploiements spécifiques de PHP.

FICHE

VULNÉRABILITÉS	CVE-2026-109618 et CVE-2026-109619
GRAVITÉ	Critique : CVSS 4.0 9,2 pour les deux (php.net) ; CVSS 3.1 (NVD) : 9,8 pour CVE-2026-109618, 8,1 pour CVE-2026-109619
IMPACT	Exécution de code à distance, sans authentification
EXPLOITATION	Preuves de concept connues du CERT-FR pour des déploiements spécifiques (22/10/2026) ; pas d'exploitation signalée par la CISA, ni d'inscription au catalogue KEV (21/10/2026)
CORRECTIF	Disponible depuis le 21/10/2026

RISQUES DE SÉCURITÉ

- Exécution de code à distance, sans authentification
- Prise de contrôle du serveur web et des applications qu'il héberge

QUI EST CONCERNÉ

Toute installation PHP qui sert des pages web est concernée, quel que soit le système : PHP-FPM, Apache avec mod_php, php-cgi, FrankenPHP et LiteSpeed. Le projet PHP juge le risque **le plus élevé pour mod_php**, où une simple

requête non authentifiée peut déclencher l'attaque avant même l'exécution du code de l'application. Sont donc exposés les sites, les CMS (WordPress, Drupal…) et les applications métier écrites en PHP.

VERSIONS CORRIGÉES

PHP 8.2	8.2.35
PHP 8.3	8.3.36
PHP 8.4	8.4.27
PHP 8.5	8.5.12
PHP 8.1 et antérieures	pas de version corrigée : migrer

CONTOURNEMENT

Aucun contournement complet selon le projet PHP : la mise à jour est la seule mesure sûre. Mesures partielles en attendant : `session.upload_progress.enabled = Off` (ne réduit l'exposition que pour CVE-2026-109619) et, sous PHP 8.5, `fatal_error_backtraces = 0` (php.net) ; bloquer, ou à défaut surveiller, les requêtes « multipart » sur les sites qui ne reçoivent pas de fichiers (CERT-FR, mesures non qualifiées par le CERT-FR).

CE QU'IL FAUT FAIRE

01 **Mettre à jour maintenant**

Passer en 8.2.35, 8.3.36, 8.4.27 ou 8.5.12, puis **redémarrer tous les processus PHP** (FPM, Apache).

02 **Traiter les versions 8.1 et antérieures**

Le projet PHP ne publie plus de version corrigée pour ces branches ; il a seulement mis à disposition des correctifs minimaux en code source pour PHP 7.4 à 8.1. Planifier la migration vers une version maintenue ou appliquer le correctif de la distribution, et isoler ces serveurs d'ici là.

03 **En attendant, réduire l'exposition**

Appliquer les mesures partielles ci-dessus. Elles ne remplacent pas la mise à jour.

04 **Surveiller**

Rechercher dans les journaux les erreurs PHP inhabituelles et les redémarrages de processus depuis le 21/10, et suivre l'évolution de l'alerte du CERT-FR.

Besoin d'aide pour évaluer votre exposition ?

Le CSIRT d'UNIDEES accompagne les organisations : inventaire des serveurs exposés, mise à jour, recherche de traces de compromission. Le CSIRT et le SOC managé d'UNIDEES sont certifiés ISO/IEC 27001:2022. Contact : commercial@unidees.dz

SOURCES OFFICIELLES

- php.net · avis de sécurité du 21/10/2026
  https://www.php.net/archive/2026.php#2026-10-21-5
- GitHub php-src · avis GHSA-w8hw-w9fx-j79w et GHSA-6wmf-4rv5-p3rp
  https://github.com/php/php-src/security/advisories
- CERT-FR · alerte CERTFR-2026-ALE-014
  https://cert.cyber.gouv.fr/alerte/CERTFR-2026-ALE-014/

- NVD · CVE-2026-109618
  https://nvd.nist.gov/vuln/detail/CVE-2026-109618
- NVD · CVE-2026-109619
  https://nvd.nist.gov/vuln/detail/CVE-2026-109619

Informations au 22/10/2026. La situation évolue : se reporter aux sources pour la dernière version.